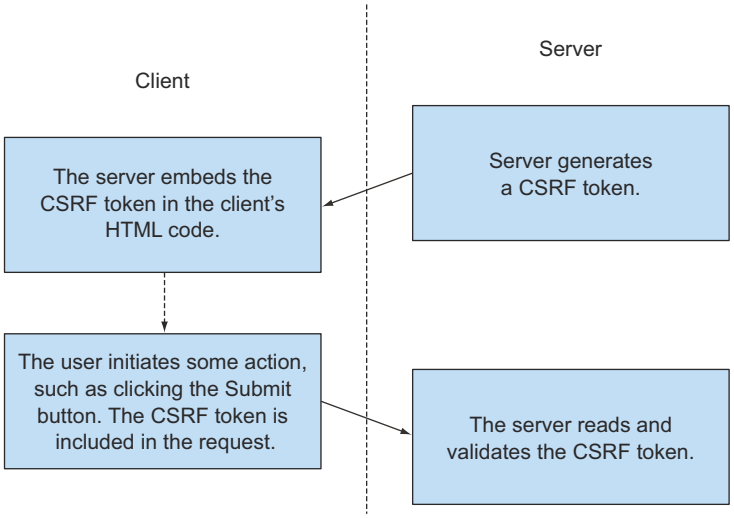


Figure C.6 Lifecycle of a CSRF token

body. In this sample, the CSRF token is included as part of the `POST` body, but it can be included anywhere in the request, including in the request URL or as a request header. The server reads the value of the CRSF token from the `_csrf` field, and checks that it's a valid value. If the token is valid, the server responds with a successful message.

Figure C.6 shows the lifecycle of the CSRF token. First, the server generates the CSRF token which is embedded somewhere in the client's HTML. When the user performs an action, such as clicking the Submit button, the request includes the CSRF token. Finally, the server reads the CSRF token and checks whether or not it's valid.

The sample also lets you change the value of the CSRF token by typing in the text box. If you navigate back to the form, edit the CSRF token to something new, and click

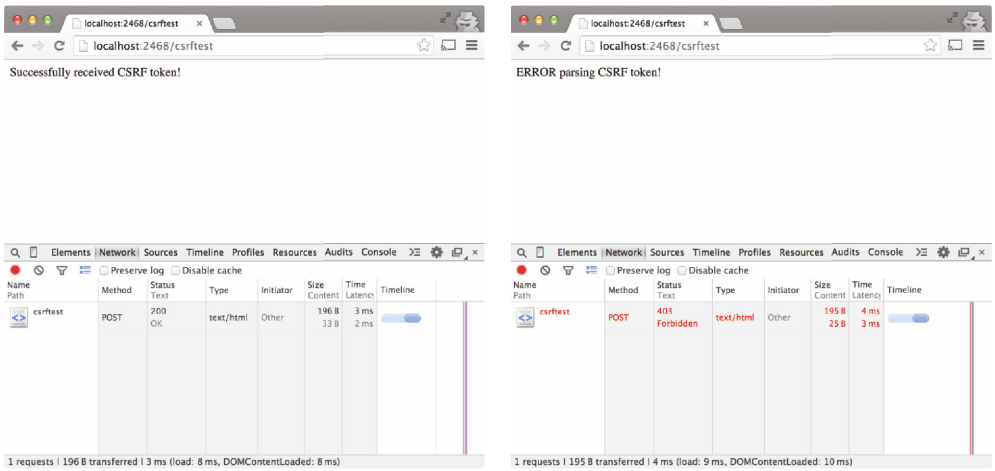


Figure C.7 Sample app with valid (left) and invalid (right) CSRF tokens